

A. Introduction

1. **Title:** Cyber Security — Personnel & Training
2. **Number:** RRC-CIP-004-1
3. **Purpose:** To minimize the risk against compromise that could result in instability, uncontrolled separations, or Cascading within the Railbelt Region Bulk Electric System (BES) from individuals accessing BES Cyber Systems (BCS) by requiring an appropriate level of personnel risk assessment, training, security awareness, and access management in support of protecting BCS.
4. **Applicability:**
 - 4.1. **Functional Entities:** For the purpose of the requirements contained herein, the following list of functional entities will be collectively referred to as “Responsible Entities.”
 - 4.1.1. **Balancing Authority/Load Balancing Authority**
 - 4.1.2. **Generator Operator**
 - 4.1.3. **Generator Owner**
 - 4.1.4. **Transmission Operator**
 - 4.1.5. **Transmission Owner**
 - 4.1.6. **Distribution Provider:** that owns one or more of the following Facilities, systems, and equipment for the protection or restoration of the BES:
 - 4.1.6.1. Each underfrequency load shedding (UFLS) or undervoltage loadshedding (UVLS) system that:
 - 4.1.6.1.1. is part of a Load shedding program that is subject to one or more requirements in an Railbelt Reliability Council Standard; and
 - 4.1.6.1.2. performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation that the loss, compromise, or misuse of could have adverse impact on the reliable operation of the BES.
 - 4.1.6.2. Each Remedial Action Scheme (RAS) where the RAS is subject to one or more requirements in an Railbelt Reliability Council Standard.
 - 4.1.6.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in an Railbelt Reliability Council Standard.
 - 4.1.6.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.
 - 4.2. **Facilities:** For the purpose of the requirements contained herein, the following Facilities, systems, and equipment owned by each Responsible Entity in 4.1 above are those to which these requirements are applicable. For requirements in this standard where a specific type of Facilities, system, or equipment or subset of Facilities, systems, and equipment are

applicable, these are specified explicitly.

4.2.1. Distribution Provider: One or more of the following Facilities, systems and equipment owned by the Distribution Provider for the protection or restoration of the BES:

4.2.1.1. Each UFLS or UVLS System that:

4.2.1.1.1. is part of a Load shedding program that is subject to one or more requirements in an Railbelt Reliability Council Standard; and

4.2.1.1.2. performs automatic Load shedding under a common control system owned by the Responsible Entity, without human operator initiation, that the loss, compromise, or misuse of could have adverse impact on the reliable operation of the BES.

4.2.1.2. Each RAS where the RAS is subject to one or more requirements in an Railbelt Reliability Council Standard.

4.2.1.3. Each Protection System (excluding UFLS and UVLS) that applies to Transmission where the Protection System is subject to one or more requirements in an Railbelt Reliability Council Standard.

4.2.1.4. Each Cranking Path and group of Elements meeting the initial switching requirements from a Blackstart Resource up to and including the first interconnection point of the starting station service of the next generation unit(s) to be started.

4.2.2. Responsible Entities listed in 4.1 other than Distribution Providers:

All BES Facilities.

4.2.3. Exemptions: The following are exempt from Standard **RRC-CIP-004-1**:

4.2.3.1. Cyber Systems at Facilities regulated by the Canadian Nuclear Safety Commission.

4.2.3.2. Cyber Assets associated with communication networks and data communication links between discrete Electronic Security Perimeters (ESP).

4.2.3.3. Cyber Systems, associated with communication networks and data communication links, between Cyber Systems, providing confidentiality and integrity of an ESP that extends to one or more geographic locations.

4.2.3.4. The systems, structures, and components that are regulated by the Nuclear Regulatory Commission under a cyber security plan pursuant to 10 C.F.R. Section 73.54.

4.2.3.5. For Distribution Providers, the systems and equipment that are not included in section 4.2.1 above.

4.2.3.6. Responsible Entities that identify that they have no BES Cyber Systems categorized as high impact or medium impact according

to the RRC-CIP-002-1 identification and categorization processes.

4.3. “Applicable Systems”: Each table has an “Applicable Systems” column to define the scope of the systems to which a specific requirement part applies.

5. Effective Dates: Shall become effective on the first day of the first calendar quarter that is twenty-four (24) months following adoption by the Approving Authority.

B. Requirements and Measures

- R1.** Each Responsible Entity shall implement one or more documented processes that collectively include each of the applicable requirement parts in *RRC-CIP-004-1 Table R1 – Security Awareness Program*. [Violation Risk Factor: Lower]
- M1.** Evidence must include each of the applicable documented processes that collectively include each of the applicable requirement parts in *RRC-CIP-004-1 Table R1 – Security Awareness Program* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-004-1 Table R1 – Security Awareness Program			
Part	Applicable Systems	Requirements	Measures
1.1	High Impact BCS Medium Impact BCS Shared Cyber Infrastructure (SCI) supporting an Applicable System in this Part.	Security awareness that, at least once each calendar quarter, reinforces cyber security practices (which may include associated physical security practices) for the Responsible Entity's personnel who have authorized electronic or authorized unescorted physical access to Applicable Systems.	An example of evidence may include, but is not limited to, documentation that the quarterly reinforcement has been provided. Examples of evidence of reinforcement may include, but are not limited to, dated copies of information used to reinforce security awareness, as well as evidence of distribution, such as: • direct communications (for example, e-mails, memos, computer-based training); or • indirect communications (for example, posters, intranet, or brochures); or • management support and reinforcement (for example, presentations or meetings).

- R2.** Each Responsible Entity shall implement one or more cyber security training program(s) appropriate to individual roles, functions, or responsibilities that collectively includes each of the applicable requirement parts in RRC-CIP-004-1 *Table R2 – Cyber Security Training Program*. [Violation Risk Factor: Lower]
- M2.** Evidence must include the training program that includes each of the applicable requirement parts in RRC-CIP-004-1 *Table R2 – Cyber Security Training Program* and additional evidence to demonstrate implementation of the program(s).

RRC-CIP-004-1 Table R2 – Cyber Security Training Program			
Part	Applicable Systems	Requirements	Measures
2.1	High Impact BCS and their associated: 1. Electronic Access Control or Monitoring Systems (EACMS); and 2. Physical Access Control Systems (PACS) Medium Impact BCS with External Routable Connectivity (ERC) and their associated: 1. EACMS; and 2. PACS Medium impact BCS with Interactive Remote Access (IRA) SCI supporting an Applicable System in this Part	Training content on: 2.1.1. Cyber security policies; 2.1.2. Physical access controls; 2.1.3. Electronic access controls; 2.1.4. The visitor control program; 2.1.5. Handling of BES Cyber System Information (BCSI) and its storage; 2.1.6. Identification of a Cyber Security Incident and initial notifications in accordance with the entity's incident response plan; 2.1.7. Recovery plans for BCS 2.1.8. Response to Cyber Security Incidents; and 2.1.9. Cyber security risks associated with a BCS electronic interconnectivity and interoperability with other Cyber Assets, including Transient Cyber Assets (TCA), and with Removable Media.	Examples of evidence may include, but are not limited to, training material such as power point presentations, instructor notes, student notes, handouts, or other training materials.

RRC-CIP-004-1 Table R2 – Cyber Security Training Program			
Part	Applicable Systems	Requirements	Measures
2.2	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Require completion of the training specified in Part 2.1 prior to granting authorized electronic access and authorized unescorted physical access to Applicable Systems, except during CIP Exceptional Circumstances.	Examples of evidence may include, but are not limited to, training records and documentation of when CIP Exceptional Circumstances were invoked.
2.3	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Require completion of the training specified in Part 2.1 at least once every 15 calendar months.	Examples of evidence may include, but are not limited to, dated individual training records.

- R3.** Each Responsible Entity shall implement one or more documented personnel risk assessment program(s) to attain and retain authorized electronic or authorized unescorted physical access to Applicable Systems that collectively include each of the applicable requirement parts in *RRC-CIP-004-1 Table R3 – Personnel Risk Assessment Program*. [Violation Risk Factor: Medium].
- M3.** Evidence must include the documented personnel risk assessment programs that collectively include each of the applicable requirement parts in *RRC-CIP-004-1 Table R3 – Personnel Risk Assessment Program* and additional evidence to demonstrate implementation of the program(s).

RRC-CIP-004-1 Table R3 – Personal Risk Assessment Program			
Part	Applicable Systems	Requirements	Measures
3.1	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS 3. Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Process to confirm Identity.	An example of evidence may include, but is not limited to, documentation of the Responsible Entity's process to confirm identity.

RRC-CIP-004-1 Table R3 – Personal Risk Assessment Program			
Part	Applicable Systems	Requirements	Measures
3.2	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Process to perform a seven year criminal history records check as part of each personnel risk assessment that includes: 3.2.1. current residence, regardless of duration; and 3.2.2. other locations where, during the seven years immediately prior to the date of the criminal history records check, the subject has resided for six consecutive months or more. If it is not possible to perform a full seven year criminal history records check, conduct as much of the seven year criminal history records check as possible and document the reason the full seven year criminal history records check could not be performed.	An example of evidence may include, but is not limited to, documentation of the Responsible Entity's process to perform a seven year criminal history records check.

RRC-CIP-004-1 Table R3 – Personal Risk Assessment Program			
Part	Applicable Systems	Requirements	Measures
3.3	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Criteria or process to evaluate criminal history records checks for authorizing access.	An example of evidence may include, but is not limited to, documentation of the Responsible Entity's process to evaluate criminal history records checks.
3.4	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Criteria or process for verifying that personnel risk assessments performed for contractors or service vendors are conducted according to Parts 3.1 through 3.3.	Examples of evidence may include, but is not limited to, documentation of the Responsible Entity's criteria or process for verifying contractors or service vendors personnel risk assessments.

RRC-CIP-004-1 Table R3 – Personal Risk Assessment Program			
Part	Applicable Systems	Requirements	Measures
3.5	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Process to ensure that individuals with authorized electronic or authorized unescorted physical access have had a personnel risk assessment completed according to Parts 3.1 to 3.4 within the last seven years.	Examples of evidence may include, but is not limited to, documentation of the Responsible Entity's process for ensuring that individuals with authorized electronic or authorized unescorted physical access have had a personnel risk assessment completed within the last seven years.

- R4.** Each Responsible Entity shall implement one or more documented access management program(s) that collectively include each of the applicable requirement parts in *RRC-CIP-004-1 Table R4 – Access Management Program*. [Violation Risk Factor: Medium].
- M4.** Evidence must include the documented processes that collectively include each of the applicable requirement parts in *RRC-CIP-004-1 Table R4 – Access Management Program* and additional evidence to demonstrate that the access management program was implemented as described in the Measures column of the table.

RRC-CIP-004-1 Table R4 – Access Management Program			
Part	Applicable Systems	Requirements	Measures
4.1	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Process to authorize based on need, as determined by the Responsible Entity, except for CIP Exceptional Circumstances: 4.1.1. Electronic access; and 4.1.2. Unescorted physical access into a Physical Security Perimeter (PSP) (except for medium impact BCS without ERC)	An example of evidence may include, but is not limited to, dated documentation of the process to authorize electronic access, unescorted physical access in a PSP.

RRC-CIP-004-1 Table R4 – Access Management Program			
Part	Applicable Systems	Requirements	Measures
4.2	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Verify at least once each calendar quarter that individuals with active electronic access or unescorted physical access have authorization records.	Examples of evidence may include, but are not limited to: • Dated documentation of the verification between the system generated list of individuals who have been authorized for access (i.e., workflow database) and a system generated list of personnel who have access (i.e., user account listing), or • Dated documentation of the verification between a list of individuals who have been authorized for access (i.e., authorization forms) and a list of individuals provisioned for access (i.e., provisioning forms or shared account listing).

RRC-CIP-004-1 Table R4 – Access Management Program			
Part	Applicable Systems	Requirements	Measures
4.3	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	For electronic access, verify at least once every 15 calendar months that all user accounts, user account groups, or user role categories, and their specific, associated privileges are correct and are those that the Responsible Entity determines are necessary.	An example of evidence may include, but is not limited to, documentation of the review that includes all of the following: 1. A dated listing of all accounts/account groups or roles within the system; 2. A summary description of privileges associated with each group or role; 3. Accounts assigned to the group or role; and 4. Dated evidence showing verification of the privileges for the group are authorized and appropriate to the work function performed by people assigned to each account.

- R5.** Each Responsible Entity shall implement one or more documented access revocation program(s) that collectively include each of the applicable requirement parts in *RRC-CIP-004-1 Table R5 – Access Revocation*. [Violation Risk Factor: Medium].
- M5.** Evidence must include each of the applicable documented programs that collectively include each of the applicable requirement parts in *RRC-CIP-004-1 Table R5 – Access Revocation* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-004-1 Table R5 – Access Revocation			
Part	Applicable Systems	Requirements	Measures
5.1	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	A process to initiate removal of an individual's ability for unescorted physical access (except for medium impact BCS without ERC) and Interactive Remote Access (IRA) upon a termination action, and complete the removals within 24 hours of the termination action (Removal of the ability for access may be different than deletion, disabling, revocation, or removal of all access rights).	An example of evidence may include, but is not limited to, documentation of all of the following: 1. Dated workflow or sign-off form verifying access removal associated with the termination action; and 2. Logs or other demonstration showing such persons no longer have access.

RRC-CIP-004-1 Table R5 – Access Revocation			
Part	Applicable Systems	Requirements	Measures
5.2	High Impact BCS and their associated: 1. EACMS; and 2. PACS Medium Impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	For reassignments or transfers, revoke the individual's authorized electronic access to individual accounts and authorized unescorted physical access that the Responsible Entity determines are not necessary by the end of the next business day following the date that the Responsible Entity determines that the individual no longer requires retention of that access.	An example of evidence may include, but is not limited to, documentation of all of the following: 1. Dated workflow or sign-off form showing a review of logical and physical access; and 2. Logs or other demonstration showing such persons no longer have access that the Responsible Entity determines is not necessary.
5.3	High Impact BES and their associated: EACMS SCI supporting an Applicable System in this Part	For termination actions, revoke the individual's non-shared user accounts (unless already revoked according to Part 5.1) within 30 calendar days of the effective date of the termination action.	An example of evidence may include, but is not limited to, workflow or sign-off form verifying access removal for any individual BES Cyber Assets and software applications as determined necessary to completing the revocation of access and dated within thirty calendar days of the termination actions.

RRC-CIP-004-1 Table R5 – Access Revocation			
Part	Applicable Systems	Requirements	Measures
5.4	High Impact BCS and their associated EACMS SCI supporting an Applicable System in this Part.	For termination actions, change passwords for shared account(s) known to the user within 30 calendar days of the termination action. For reassignments or transfers, change passwords for shared account(s) known to the user within 30 calendar days following the date that the Responsible Entity determines that the individual no longer requires retention of that access. If the Responsible Entity determines and documents that extenuating operating circumstances require a longer time period, change the password(s) within 10 calendar days following the end of the operating circumstances.	Examples of evidence may include, but are not limited to: • Workflow or sign-off form showing password reset within 30 calendar days of the termination action; • Workflow or sign-off form showing password reset within 30 calendar days of the reassignments or transfers; or • Documentation of the extenuating operating circumstance and workflow or sign-off form showing password reset within 10 calendar days following the end of the operating circumstance.

- R6.** Each Responsible Entity shall implement one or more documented access management program(s) to authorize, verify, and revoke provisioned access to BCSI pertaining to the Applicable Systems identified in *RRC-CIP-004-8 Table R6 – Access Management for BES Cyber System Information* that collectively include each of the applicable requirement parts in *RRC-CIP-004-8 Table R6 – Access Management for BES Cyber System Information*. To be considered access to BCSI in the context of this requirement, an individual has both the ability to obtain and use BCSI. Provisioned access is to be considered the result of the specific actions taken to provide an individual(s) the means to access BCSI (e.g., may include physical keys or access cards, user accounts and associated rights and privileges, encryption keys). *[Violation Risk Factor: Medium] [Time Horizon: Same Day Operations and Operations Planning]*.
- M6.** Evidence must include each of the applicable documented programs that collectively include the applicable requirement parts in *RRC-CIP-004-1 Table R6 – Access Management for BES Cyber System Information* and additional evidence to demonstrate implementation as described in the Measures column of the table.

RRC-CIP-004-1 Table R6 – Access Management for BES Cyber System Information			
Part	Applicable Systems	Requirements	Measures
6.1	High impact BCS and their associated: 1. EACMS; and 2. PACS Medium impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Prior to provisioning, authorize (unless already authorized according to Part 4.1) based on need, as determined by the Responsible Entity, except for CIP Exceptional Circumstances: 6.1.1. Provisioned electronic access to electronic BCSI; and 6.1.2. Provisioned physical access to physical BCSI (except for BCSI at a medium impact BCS without ERC).	Examples of evidence may include, but are not limited to, individual records or lists that include who is authorized, the date of the authorization, and the justification of business need for the provisioned access.

RRC-CIP-004-1 Table R6 – Access Management for BES Cyber System Information			
Part	Applicable Systems	Requirements	Measures
6.2	High impact BCS and their associated: 1. EACMS; and 2. PACS Medium impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	Verify at least once every 15 calendar months that all individuals with provisioned access to BCSI: 6.2.1. have an authorization record; and 6.2.2. still need the provisioned access to perform their current work functions, as determined by the Responsible Entity.	Examples of evidence may include, but are not limited to, the documentation of the review that includes all of the following: • List of authorized individuals; • List of individuals who have been provisioned access; • Verification that provisioned access is appropriate based on need; and • Documented reconciliation actions, if any.
6.3	High impact BCS and their associated: 1. EACMS; and 2. PACS Medium impact BCS with ERC and their associated: 1. EACMS; and 2. PACS Medium impact BCS with IRA SCI supporting an Applicable System in this Part	For termination actions, remove the individual's ability to use provisioned access to BCSI (unless already revoked according to Part 5.1) (except for BCSI at a medium impact BCS without ERC) by the end of the next calendar day following the effective date of the termination action.	Examples of dated evidence may include, but are not limited to, access revocation records associated with the terminations and dated within the next calendar day of the termination action.

C. Compliance

1 Compliance Monitoring Process

1.1 Compliance Enforcement Authority:

The RRC is the entity with the authority to monitor and enforce compliance with mandatory and enforceable Railbelt Reliability Council Standards.

1.2 Evidence Retention:

The following evidence retention periods identify the period of time an entity is required to retain specific evidence to demonstrate compliance. For instances where the evidence retention period specified below is shorter than the time since the last audit, the RRC may ask an entity to provide other evidence to show that it was compliant for the full time period since the last audit.

The Responsible Entity shall keep data or evidence to show compliance as identified below unless directed by its RRC to retain specific evidence for a longer period of time as part of an investigation:

- Each Responsible Entity shall retain evidence of each requirement in this standard for three calendar years.
- If a Responsible Entity is found non-compliant, it shall keep information related to the non-compliance until mitigation is complete and approved or for the time specified above, whichever is longer.
- The RRC shall keep the last audit records and all requested and submitted subsequent audit records.

1.3 Compliance Monitoring and Enforcement Program:

Compliance Monitoring and Enforcement Program refers to the identification of the processes that will be used to evaluate data or information for the purpose of assessing performance or outcomes with the associated Railbelt Reliability Council Standards.

Table of Compliance Elements

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R1	Lower	The Responsible Entity did not reinforce cyber security practices during a calendar quarter but did so less than 10 calendar days after the end of the required quarter. (R 1.1)	The Responsible Entity did not reinforce cyber security practices during a calendar quarter but did so between 10 and 25 calendar days after the end of the required quarter. (R 1.1)	The Responsible Entity did not reinforce cyber security practices during a calendar quarter but did so between 25 and 40 calendar days after the end of the required quarter. (R 1.1)	The Responsible Entity did not reinforce cyber security practices during a calendar quarter but did so between 40 and 55 calendar days after the end of the required quarter. (R 1.1) OR The Responsible Entity did not reinforce cyber security practices and associated physical security practices for at least two consecutive calendar quarters. (R 1.1)
R2	Lower	The Responsible Entity implemented a cyber security training program but failed to include one of the training content topics in Requirement Parts 2.1.1 through 2.1.9. (R 2.1) OR The Responsible Entity implemented a cyber security training program but failed to train one individual (with the exception of RRC-CIP Exceptional Circumstances) prior to their being granted authorized electronic and	The Responsible Entity implemented a cyber security training program but failed to include more than one but less than or equal to three of the training content topics in Requirement Parts 2.1.1 through 2.1.9. (R 2.1) OR The Responsible Entity implemented a cyber security training program but failed to train more than one but less than or equal to three individuals (with the	The Responsible Entity implemented a cyber security training program but failed to include more than three but less than or equal to six of the training content topics in Requirement Parts 2.1.1 through 2.1.9. (R 2.1) OR The Responsible Entity implemented a cyber security training program but failed to train more than three but less than or equal to six individuals (with the	The Responsible Entity did not implement a cyber security training program appropriate to individual roles, functions, or responsibilities. (R2) OR The Responsible Entity implemented a cyber security training program but failed to include more than six of the training content topics in Requirement Parts 2.1.1 through 2.1.9. (R 2.1)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		authorized unescorted physical access. (R 2.2) OR The Responsible Entity implemented a cyber security training program but failed to train one individual with authorized electronic or authorized unescorted physical access within 15 calendar months of the previous training completion date. (R 2.3)	exception of RRC-CIP Exceptional Circumstances) prior to their being granted authorized electronic and authorized unescorted physical access. (R 2.2) OR The Responsible Entity implemented a cyber security training program but failed to train more than one but less than or equal to three individuals with authorized electronic or authorized unescorted physical access within 15 calendar months of the previous training completion date. (R 2.3)	exception of RRC-CIP Exceptional Circumstances) prior to their being granted authorized electronic and authorized unescorted physical access. (R 2.2) OR The Responsible Entity implemented a cyber security training program but failed to train more than three but less than or equal to six individuals with authorized electronic or authorized unescorted physical access within 15 calendar months of the previous training completion date. (R 2.3)	OR The Responsible Entity implemented a cyber security training program but failed to train more than six individuals (with the exception of RRC-CIP Exceptional Circumstances) prior to their being granted authorized electronic and authorized unescorted physical access. (R 2.2) OR The Responsible Entity implemented a cyber security training program but failed to train more than six individuals with authorized electronic or authorized unescorted physical access within 15 calendar months of the previous training completion date. (R 2.3)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R3	Medium	The Responsible Entity has a program for conducting Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, but did not conduct the PRA as a condition of granting authorized electronic or authorized unescorted physical access for one individual. (R3) OR The Responsible Entity did conduct Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not confirm identity for one individual. (R 3.1 & 3.4) OR The Responsible Entity has a process to perform seven- year criminal history record checks for individuals, including contractors and service vendors, with authorized	The Responsible Entity has a program for conducting Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, but did not conduct the PRA as a condition of granting authorized electronic or authorized unescorted physical access for more than one but less than or equal to two individuals. (R3) OR The Responsible Entity did conduct Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not confirm identity for more than one but less than or equal to two individuals. (R 3.1 & 3.4) OR The Responsible Entity has a process to perform seven- year criminal	The Responsible Entity has a program for conducting Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, but did not conduct the PRA as a condition of granting authorized electronic or authorized unescorted physical access for more than two but less than or equal to four individuals. (R3) OR The Responsible Entity did conduct Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not confirm identity for more than two but less than or equal to four individuals. (R 3.1 & 3.4) OR The Responsible Entity has a process to perform seven- year criminal history record checks for individuals, including contractors and service vendors, with	The Responsible Entity did not have all of the required elements as described by 3.1 through 3.4 included within documented program(s) for implementing Personnel Risk Assessments (PRAs), for individuals, including contractors and service vendors, for obtaining and retaining authorized cyber or authorized unescorted physical access. (R3) OR The Responsible Entity has a program for conducting Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, but did not conduct the PRA as a condition of granting authorized electronic or authorized unescorted physical access for more than four individuals. (R3) OR The Responsible Entity did conduct Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, with authorized

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		electronic or authorized unescorted physical access but did not include the required checks described in 3.2.1 and 3.2.2 for one individual. (R 3.2 & 3.4) OR The Responsible Entity did conduct Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not evaluate criminal history records check for access authorization for one individual. (R 3.3 & 3.4) OR The Responsible Entity did not conduct Personnel Risk Assessments (PRAs) for one individual with authorized electronic or authorized unescorted physical access within 7 calendar years of the previous PRA completion date. (R 3.5)	history record checks for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not include the required checks described in 3.2.1 and 3.2.2 for more than one but less than or equal to two individuals. (R 3.2 & 3.4) OR The Responsible Entity did conduct Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not evaluate criminal history records check for access authorization for more than one but less than or equal to two individuals. (R 3.3 & 3.4) OR The Responsible Entity did not conduct Personnel Risk Assessments (PRAs) for more than one but less than or	authorized electronic or authorized unescorted physical access but did not include the required checks described in 3.2.1 and 3.2.2 for more than two but less than or equal to four individuals. (R 3.2 & 3.4) OR The Responsible Entity did conduct Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not evaluate criminal history records check for access authorization for two but less than or equal to four individuals. (3.3 & 3.4) OR The Responsible Entity did not conduct Personnel Risk Assessments (PRAs) for two but less than or equal to four individuals with authorized electronic or authorized unescorted physical access within 7 calendar years of the previous PRA completion date. (R 3.5)	electronic or authorized unescorted physical access but did not confirm identity for more than four individuals. (R 3.1 & 3.4) OR The Responsible Entity has a process to perform seven-year criminal history record checks for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not include the required checks described in 3.2.1 and 3.2.2 for more than four individuals. (R 3.2 & 3.4) OR The Responsible Entity did conduct Personnel Risk Assessments (PRAs) for individuals, including contractors and service vendors, with authorized electronic or authorized unescorted physical access but did not evaluate criminal history records check for access authorization for more than four individuals. (R 3.3 & 3.4)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
			equal to two individuals with authorized electronic or authorized unescorted physical access within 7 calendar years of the previous PRA completion date. (R 3.5)		OR The Responsible Entity did not conduct Personnel Risk Assessments (PRAs) for more than four individuals with authorized electronic or authorized unescorted physical access within 7 calendar years of the previous PRA completion date. (R 3.5)
R4	Medium	The Responsible Entity did not authorize electronic access or unescorted physical access based on need for one individual. (R 4.1) OR The Responsible Entity did not verify that individuals with active electronic or active unescorted physical access have authorization records during a calendar quarter but did so less than 10 calendar days after the	The Responsible Entity did not authorize electronic access or unescorted physical access based on need for more than one but less than or equal to two individuals. (R 4.1) OR The Responsible Entity did not verify that individuals with active electronic or active unescorted physical access have authorization records during a calendar quarter but did so between 10 and 20 calendar days	The Responsible Entity did not authorize electronic access or unescorted physical access based on need for more than two but less than or equal to four individuals. (R 4.1) OR The Responsible Entity did not verify that individuals with active electronic or active unescorted physical access have authorization records during a calendar quarter but did so between 20 and 30 calendar days	The Responsible Entity did not implement any documented program(s) for access management. (Requirement R4) OR The Responsible Entity did not authorize electronic access or unescorted physical access based on need for more than four individuals. (R 4.1) OR

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		end of the required calendar quarter. (R 4.2) OR The Responsible Entity did not verify that user accounts, user account groups, or user role categories, and their specific, associated privileges are correct and necessary within 15 calendar months of the previous verification but for 5% or less of its BCS or SCI, privileges were incorrect or unnecessary. (R 4.3)	after the end of the required calendar quarter. (R 4.2) OR The Responsible Entity did not verify that user accounts, user account groups, or user role categories, and their specific, associated privileges are correct and necessary within 15 calendar months of the previous verification for more than 5% but less than (or equal to) 10% of its BCS or SCI, privileges were incorrect or unnecessary. (R 4.3)	after the end of the required calendar quarter. (R 4.2) OR The Responsible Entity did not verify that user accounts, user account groups, or user role categories, and their specific, associated privileges are correct and necessary within 15 calendar months of the previous verification for more than 10% but less than (or equal to) 15% of its BCS or SCI, privileges were incorrect or unnecessary. (R 4.3)	The Responsible Entity did not verify that individuals with active electronic or active unescorted physical access have authorization records for at least two consecutive calendar quarters. (R 4.2) OR The Responsible Entity did not verify that user accounts, user account groups, or user role categories, and their specific, associated privileges are correct and necessary within 15 calendar months of the previous verification for more than 15% of its BCS or SCI, privileges were incorrect or unnecessary. (R 4.3)

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
R5	Medium	The Responsible Entity did not initiate removal of the ability for unescorted physical access and IRA upon a termination action or complete the removal within 24 hours of the termination action for one individual. (R 5.1) OR The Responsible Entity did not revoke individual's user accounts upon termination action within 30 calendar days of the date of termination action for one or more individuals. (R 5.3) OR The Responsible Entity did not change passwords for shared accounts known to the user upon termination action, reassignment, or transfer within 30 calendar days of the date of termination action, reassignment, or transfer for	The Responsible Entity did not initiate removal of the ability for unescorted physical access and IRA upon a termination action or complete the removal within 24 hours of the termination action for more than one but less than or equal to two individuals. (R 5.1) OR The Responsible Entity for one individual, did not revoke the authorized electronic access to individual accounts and authorized unescorted physical access by the end of the next calendar day following the predetermined date. (R 5.2)	The Responsible Entity did not initiate removal of the ability for unescorted physical access and IRA upon a termination action or complete the removal within 24 hours of the termination action for more than two but less than or equal to four individuals. (R 5.1) OR The Responsible Entity for more than one but less than or equal to two individuals, did not revoke the authorized electronic access to individual accounts and authorized unescorted physical access by the end of the next calendar day following the predetermined date. (R 5.2)	The Responsible Entity has not implemented any documented program(s) for access revocation for electronic access or unescorted physical access. (Requirement R5) OR The Responsible Entity did not initiate removal of the ability for unescorted physical access and Interactive Remote Access upon a termination action or complete the removal within 24 hours of the termination action for more than four individuals. (R 5.1) OR The Responsible Entity for more than two individuals, did not revoke the authorized electronic access to individual accounts and authorized unescorted physical access by the end of the next calendar day

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		one or more individuals. (R 5.4) OR The Responsible Entity did not change one or more passwords for shared accounts known to the user within 10 calendar days following the end of the extenuating operating circumstances. (R 5.4)			following the predetermined date. (R 5.2)
R6	Medium	The Responsible Entity, for one individual, did not authorize provisioned electronic access to electronic BCSI or provisioned physical access to physical BCSI. (R 6.1) OR The Responsible Entity did not perform the verification required by 6.2 within 15 calendar months but did in less than or equal to 17 calendar months of the previous verification. (R 6.2)	The Responsible Entity, for more than one but less than or equal to two individuals, did not authorize provisioned electronic access to electronic BCSI or provisioned physical access to physical BCSI. (R 6.1) OR The Responsible Entity did not perform the verification required by 6.2 within 17 calendar months but did in less than or equal to 19 calendar months of the previous verification. (R 6.2)	The Responsible Entity, for more than two but less than or equal to four individuals, did not authorize provisioned electronic access to electronic BCSI or provisioned physical access to physical BCSI. (R 6.1) OR The Responsible Entity did not perform the verification required by 6.2 within 19 calendar months but less than or equal to 21 calendar months of the previous verification. (R 6.2)	The Responsible Entity did not implement one or more documented access management program(s) for BCSI. (Requirement R6) OR The Responsible Entity, for more than four individuals, did not authorize provisioned electronic access to electronic BCSI or provisioned physical access to physical BCSI. (R 6.1) OR

R#	Violation Risk Factor (VRF)	Violation Severity Levels (RRC-CIP-004-1)			
		Lower VSL	Moderate VSL	High VSL	Severe VSL
		OR The Responsible Entity, for one individual, did not remove the individual's ability to use provisioned access to BCSI by the timeframe required in 6.3.	OR The Responsible Entity, for more than one but less than or equal to two individuals, did remove each individual's ability to use provisioned access to BCSI by the timeframe required in 6.3.	OR The Responsible Entity, for more than two but less than or equal to four individuals, did not remove each individual's ability to use provisioned access to BCSI by the timeframe required in 6.3.	The Responsible Entity did not perform the verification required by 6.2 more than 21 calendar months of the previous verification. (R 6.2) OR The Responsible Entity, for more than four individuals, did not remove each individual's ability to use provisioned access to BCSI by the timeframe required in 6.3.

D. Regional Variances

None.

E. Interpretations

None.

F. Associated Documents

None

Version History

Version	Date	Action	Change Tracking

GLOSSARY

Balancing Authority	The responsible entity that integrates resource plans ahead of time, maintains Demand and resource balance within a Balancing Authority Area, and supports Interconnection frequency in real time.
BES Cyber Asset (BCA)	A Cyber Asset that if rendered unavailable, degraded, or misused would, within 15 minutes of its required operation, misoperation, or non operation, adversely impact one or more Facilities, systems, or equipment, which, if destroyed, degraded, or otherwise rendered unavailable when needed, would affect the reliable operation of the Bulk Electric System. Redundancy of affected Facilities, systems, and equipment shall not be considered when determining adverse impact. Each BES Cyber Asset is included in one or more BES Cyber Systems.
BES Cyber System (BCS)	One or more BES Cyber Assets logically grouped by a responsible entity to perform one or more reliability tasks for a functional entity.
BES Cyber System Information	Information about the BES Cyber System that could be used to gain unauthorized access or pose a security threat to the BES Cyber System. BES Cyber System Information does not include individual pieces of information that by themselves do not pose a threat or could not be used to allow unauthorized access to BES Cyber Systems, such as, but not limited to, device names, individual IP addresses without context, ESP names, or policy statements. Examples of BES Cyber System Information may include, but are not limited to, security procedures or security information about BES Cyber Systems, Physical Access Control Systems, and Electronic Access Control or Monitoring Systems that is not publicly available and could be used to allow unauthorized access or unauthorized distribution; collections of network addresses; and network topology of the BES Cyber System.
Blackstart Resource	A generating unit(s) and its associated set of equipment which has the ability to be started without support from the System or is designed to remain energized without connection to the remainder of the System, with the ability to energize a bus, meeting the Transmission Operator's restoration plan needs for Real and Reactive Power capability, frequency and voltage control, and that has been included in the Transmission Operator's restoration plan.
Bulk Electric System	Unless modified by the lists shown below, all Transmission Elements operated at 100 kV or higher and Real Power and Reactive Power resources connected at 100 kV or higher. This does not include facilities used in the local distribution of electric energy. Inclusions:

	• I1 - Transformers with the primary terminal and at least one secondary terminal operated at 100 kV or higher unless excluded by application of Exclusion E1 or E3. • I2 – Generating resource(s) including the generator terminals through the high-side of the step-up transformer(s) connected at a voltage of 100 kV or above with: a) Gross individual nameplate rating greater than 20 MVA. Or, b) Gross plant/facility aggregate nameplate rating greater than 75 MVA. • I3 - Blackstart Resources identified in the Transmission Operator’s restoration plan. • I4 - Dispersed power producing resources that aggregate to a total capacity greater than 75 MVA (gross nameplate rating), and that are connected through a system designed primarily for delivering such capacity to a common point of connection at a voltage of 100 kV or above. Thus, the facilities designated as BES are: a) The individual resources, and The system designed primarily for delivering capacity from the point where those resources aggregate to greater than 75 MVA to a common point of connection at a voltage of 100 kV or above. • I5 –Static or dynamic devices (excluding generators) dedicated to supplying or absorbing Reactive Power that are connected at 100 kV or higher, or through a dedicated transformer with a high-side voltage of 100 kV or higher, or through a transformer that is designated in Inclusion I1 unless excluded by application of Exclusion E4 Exclusions: • E1 - Radial systems: A group of contiguous transmission Elements that emanates from a single point of connection of 100 kV or higher and: a) Only serves Load. Or, b) Only includes generation resources, not identified in Inclusions I2, I3, or I4, with an aggregate capacity less than or equal to 75 MVA (gross nameplate rating). Or, c) Where the radial system serves Load and includes generation resources, not identified in Inclusions I2, I3 or I4, with an aggregate capacity of non-retail generation less than or equal to 75 MVA (gross nameplate rating). Note 1 – A normally open switching device between radial systems, as depicted on prints or one-line diagrams for example, does not affect this exclusion. Note 2 – The presence of a contiguous loop, operated at a voltage level of 50 kV or less, between configurations being considered as radial systems, does not affect this exclusion. • E2 - A generating unit or multiple generating units on the customer’s side of the retail meter that serve all or part of the retail Load with electric energy if: (i) the net capacity provided to the BES does not exceed 75 MVA, and (ii) standby, back-up, and maintenance power services are provided to the
--	--

	generating unit or multiple generating units or to the retail Load by a Balancing Authority, or provided pursuant to a binding obligation with a Generator Owner or Generator Operator, or under terms approved by the applicable regulatory authority. • E3 - Local networks (LN): A group of contiguous transmission Elements operated at less than 300 kV that distribute power to Load rather than transfer bulk power across the interconnected system. LN's emanate from multiple points of connection at 100 kV or higher to improve the level of service to retail customers and not to accommodate bulk power transfer across the interconnected system. The LN is characterized by all of the following: a) Limits on connected generation: The LN and its underlying Elements do not include generation resources identified in Inclusions I2, I3, or I4 and do not have an aggregate capacity of non-retail generation greater than 75 MVA (gross nameplate rating); b) Real Power flows only into the LN and the LN does not transfer energy originating outside the LN for delivery through the LN; and c) Not part of a Flowgate or transfer path: The LN does not contain any part of a permanent Flowgate in the Eastern Interconnection, a major transfer path within the Western Interconnection, or a comparable monitored Facility in the ERCOT or Quebec Interconnections, and is not a monitored Facility included in an Interconnection Reliability Operating Limit (IROL). • E4 – Reactive Power devices installed for the sole benefit of a retail customer(s). Note - Elements may be included or excluded on a case-by-case basis through b) the Rules of Procedure exception process.
CIP Exceptional Circumstance	A situation that involves or threatens to involve one or more of the following, or similar, conditions that impact safety or BES reliability: a risk of injury or death; a natural disaster; civil unrest; an imminent or existing hardware, software, or equipment failure; a Cyber Security Incident requiring emergency assistance; a response by emergency services; the enactment of a mutual assistance agreement; or an impediment of large scale workforce availability.
CIP Senior Manager	A single official with the authority to bind the registered entity to adhere to the requirements within the CIP Standards, CIP-002 through CIP-015.
Control Center	One or more facilities hosting operating personnel that monitor and control the Bulk Electric System (BES) in real-time to perform the reliability tasks, including their associated data centers, of: 1) a Reliability Coordinator, 2) a Balancing Authority, 3) a Transmission Operator for transmission Facilities at two or more locations, or 4) a Generator Operator for generation Facilities at two or more locations.
Cranking Path	A portion of the electric system that can be isolated and then energized to deliver electric power from a generation source to enable the startup of one or more other generating units.

Glossary

Cyber Assets	Programmable electronic devices, including the hardware, software, and data in those devices.
Distribution Provider	Provides and operates the “wires” between the transmission system and the end-use customer. For those end-use customers who are served at transmission voltages, the Transmission Owner also serves as the Distribution Provider. Thus, the Distribution Provider is not defined by a specific voltage, but rather as performing the distribution function at any voltage
Electronic Access Control or Monitoring Systems	Cyber Assets that perform electronic access control or electronic access monitoring of the Electronic Security Perimeter(s) or BES Cyber Systems. This includes Intermediate Systems.
Electronic Access Point	A Cyber Asset interface on an Electronic Security Perimeter that allows routable communication between Cyber Assets outside an Electronic Security Perimeter and Cyber Assets inside an Electronic Security Perimeter.
Electronic Security Perimeter	The logical border surrounding a network to which BES Cyber Systems are connected using a routable protocol.
Electronic Access Control or Monitoring Systems	Cyber System(s) that perform electronic access control or electronic access monitoring of the Electronic Security Perimeter(s) (ESP) or BES Cyber Systems (BCS), including those not protected by an ESP used by the responsible entity to convert routable protocol communications to non-routable communications to a BCS.
Element	Any electrical device with terminals that may be connected to other electrical devices such as a generator, transformer, circuit breaker, bus section, or transmission line. An Element may be comprised of one or more components.
External Routable Connectivity	Programmable electronic devices, excluding Shared Cyber Infrastructure, including the hardware, software, and data in those devices. Application containers are considered software of Virtual Cyber Assets (VCAs) or Cyber Assets. VCAs are not considered software or data of Cyber Assets.
Interactive Remote Access	User-initiated electronic access by a person using a bidirectional routable protocol: • To a Cyber System protected by an Electronic Security Perimeter(s) (ESP); • That is converted by the responsible entity to a non-routable protocol that allows access to a Cyber System; or • To a Management Interface. Interactive Remote Access does not include:

Glossary

	• Communication that originates from a Cyber System protected by any of the Responsible Entity's ESPs; or • System-to-system process communication.
Physical Access Control Systems	Cyber Systems that control, alert, or log access to the Physical Security Perimeter(s) (PSP), exclusive of locally mounted hardware or devices at the PSP such as motion sensors, electronic lock control mechanisms, and badge readers.
Shared Cyber Infrastructure	One or more programmable electronic devices, including the software that shares the devices' resources, that: • Hosts one or more Virtual Cyber Assets (VCA) included in a BES Cyber Systems (BCS) or their associated Electronic Access Control or Monitoring Systems (EACMS) or Physical Access Control Systems (PACS); and hosts one or more VCAs that are not included in, or associated with, BCS of the same impact categorization; or • Provides storage resources required for system functionality of one or more Cyber Assets or VCAs included in a BCS or their associated EACMS or PACS; and also for one or more Cyber Assets or VCAs that are not included in, or associated with, BCS of the same impact categorization. SCI does not include the supported VCAs or Cyber Assets with which it shares its resources.
System	A combination of generation, transmission, and distribution components.
Transient Cyber Asset	A Cyber Asset or Virtual Cyber Asset (VCA) that is: 1. Capable of transmitting or transferring executable code; 2. Not included in a BES Cyber System (BCS); 3. Not a Protected Cyber Asset (PCA) associated with high or medium impact BCS; and 4. Connected for 30 consecutive calendar days or less: • On a network protected by an Electronic Security Perimeter containing high or medium impact BCS; or • Directly (e.g., using Ethernet, serial, Universal Serial Bus, or wireless including near field or Bluetooth communication) to a: ▪ BES Cyber Asset; ▪ Shared Cyber Infrastructure; or ▪ PCA associated with high or medium impact BCS. Virtual machines hosted on a physical Transient Cyber Asset (TCA) are treated as software on that physical TCA. Examples of TCAs include, but are not limited to, Cyber Assets or VCAs used for data transfer, vulnerability assessment, maintenance, or troubleshooting purposes.